



ROAD TO HALL OF FAME

Bypass por Eliminación No Recursiva

Actividad 09 · Reporte de laboratorio

Ingeniería en Tecnologías de la Información

Universidad Politécnica de San Luis Potosí

Fundamentos de Ciberseguridad

Mtro. Servando López Contreras

Juan Francisco Ortega Jiménez · Matrícula 184918

23 de septiembre de 2026



Road to Hall of Fame — Bypass por Eliminación No Recursiva

1. Datos generales del laboratorio

Nombre del laboratorio	File path traversal, traversal sequences stripped non-recursively
Nivel	Practitioner
Tipo de explotación	Path Traversal / Directory Traversal — bypass de filtro de eliminación no recursiva
Objetivo del laboratorio	Obtener el contenido del archivo /etc/passwd explotando el parámetro "filename", evadiendo un filtro que elimina las secuencias "../" una sola vez.
URL del laboratorio	https://portswigger.net/web-security/file-path-traversal/lab-sequences-stripped-non-recursively

2. Explicación técnica de la vulnerabilidad

Este laboratorio implementa una defensa que elimina ("strips") las secuencias de salto de directorios ("../") del valor recibido en el parámetro filename antes de usarlo. A diferencia del caso simple, aquí la aplicación sí intenta sanear activamente la entrada, buscando el patrón "../" y removiéndolo del string.

Sin embargo, la eliminación del patrón se realiza de forma no recursiva: el filtro recorre el string una única vez, elimina las coincidencias de "../" que encuentra, y no vuelve a analizar el resultado para verificar si, tras la eliminación, se formó una nueva secuencia "../" a partir de los caracteres restantes.

Esto permite construir un payload donde, al insertar secuencias "../" adicionales dentro de otras, el filtro elimina únicamente la ocurrencia interna y dejar intacta una secuencia funcional. Por ejemplo, al enviar "....//", el filtro detecta y elimina el "../" contenido en esa cadena, pero los caracteres restantes se recombinan formando un nuevo "../" válido, que nunca es analizado nuevamente. Esta vulnerabilidad también corresponde a OWASP Top 10 – A01:2021 Broken Access Control.

3. Procedimiento paso a paso

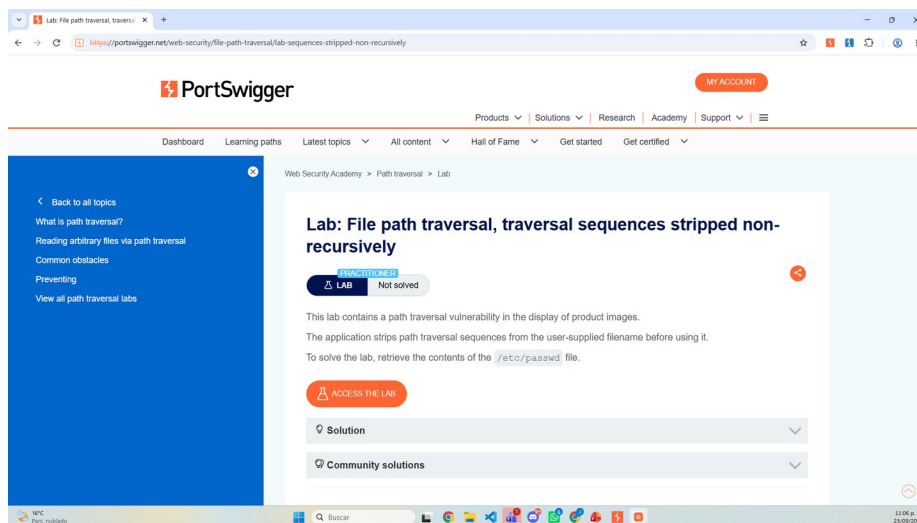
- Abrir Burp Suite Community Edition y crear un "Temporary project in memory" con la configuración por defecto.
- Acceder a la URL del laboratorio e iniciar sesión con la cuenta de PortSwigger; dar clic en "Access the lab".
- En la tienda ("We Like To Shop"), navegar entre los productos para generar tráfico hacia el servidor.
- Ajustar el filtro de HTTP history en Burp: marcar la casilla "Images" en "Filter by MIME type" y quitar las extensiones jpg/png del campo "Hide" en "Filter by file extension", ya que el filtro por defecto oculta las peticiones de imagen.
- Con el filtro corregido, localizar en HTTP history una petición GET /image? filename=NOMBRE.jpg.
- Seleccionar esa petición, clic derecho → "Send to Repeater", e ir a la pestaña Repeater.
- En Repeater, reemplazar el valor del parámetro filename por el payload de bypass no recursivo://....//....//etc/passwd (cada bloque "....//" contiene un "../" que, al ser eliminado una sola vez por el filtro, deja un "../" funcional en su lugar).
- Enviar la petición (Send / Ctrl+Enter) y revisar el panel de respuesta: el servidor devuelve "HTTP/2 200 OK" con el contenido completo de /etc/passwd.
- Regresar a la pestaña del laboratorio en PortSwigger, refrescar la página y confirmar que el estatus cambia de "Not solved" a "Solved".

4. Evidencias fotográficas del proceso

A continuación se documenta, en orden cronológico, cada paso realizado durante la explotación del laboratorio, con su captura de pantalla correspondiente.

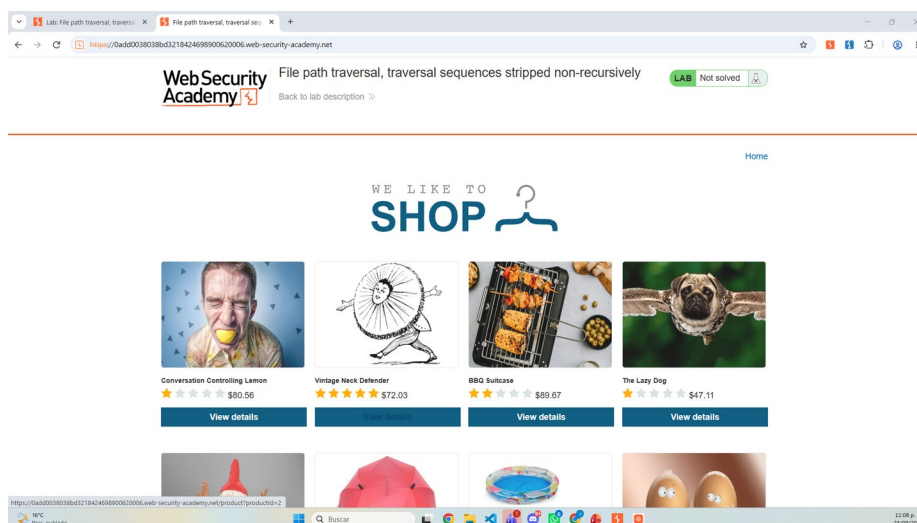
4.1 Página del laboratorio (estado inicial)

Página oficial del laboratorio en PortSwigger, mostrando el nivel "Practitioner", el estado inicial "Not solved" y la descripción del reto: la aplicación elimina las secuencias de traversal del filename antes de usarlo.



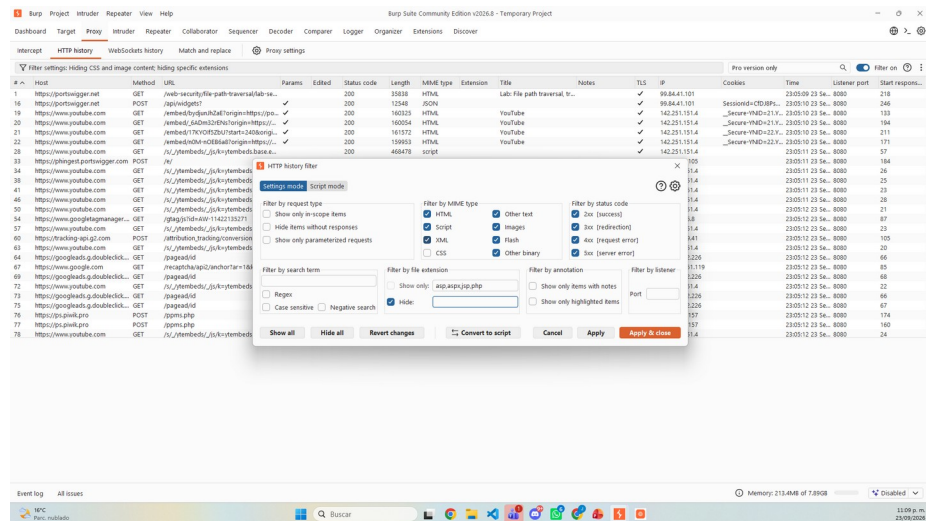
4.2 Generación de tráfico en la tienda

Se accedió a la tienda ("We Like To Shop") y se navegó entre los productos para generar peticiones GET /image?filename= hacia el servidor, necesarias para poder interceptarlas en Burp.



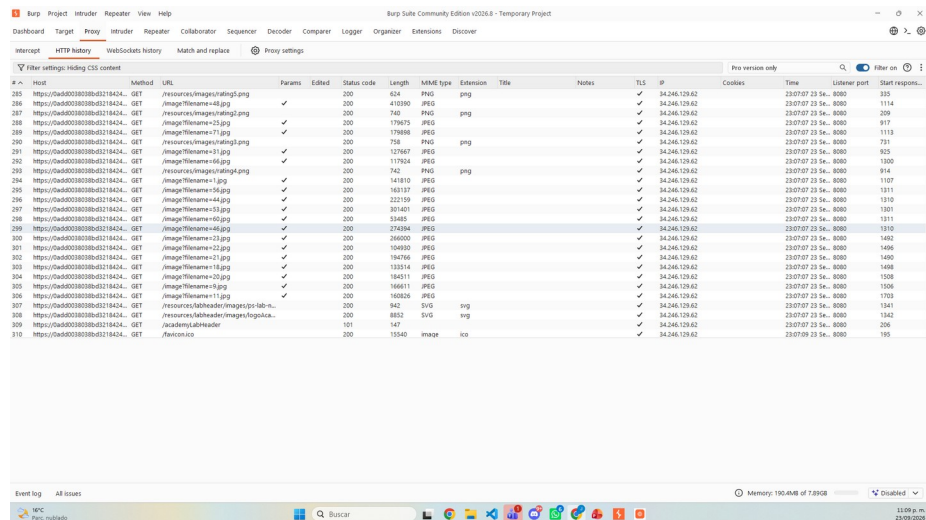
4.3 Ajuste del filtro de HTTP history

Se abrió el diálogo de filtros de HTTP history y se marcó la casilla "Images" en "Filter by MIME type", dejando vacío el campo "Hide" en "Filter by file extension", para poder visualizar las peticiones a archivos de imagen.



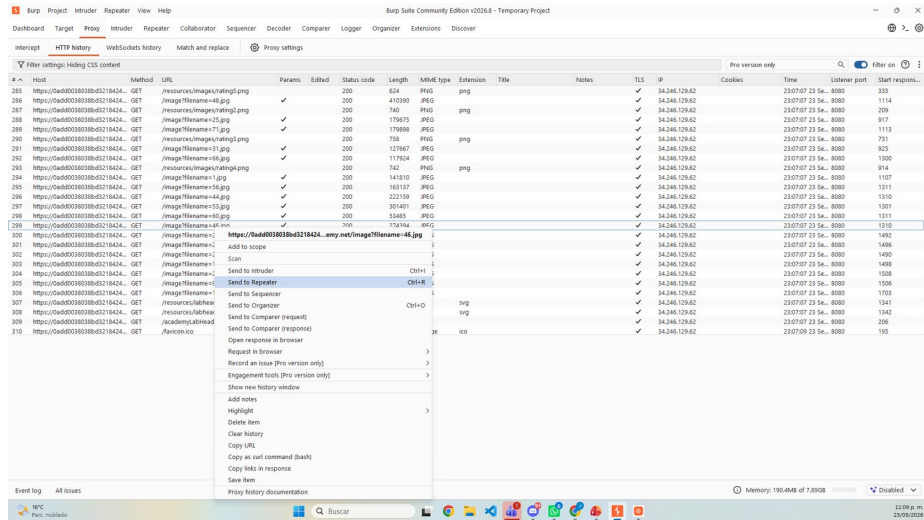
4.4 Request interceptado

Con el filtro corregido, las peticiones GET /image?filename=XX.jpg quedaron visibles en HTTP history. Se seleccionó una de ellas (filename=46.jpg) para continuar con el ataque.



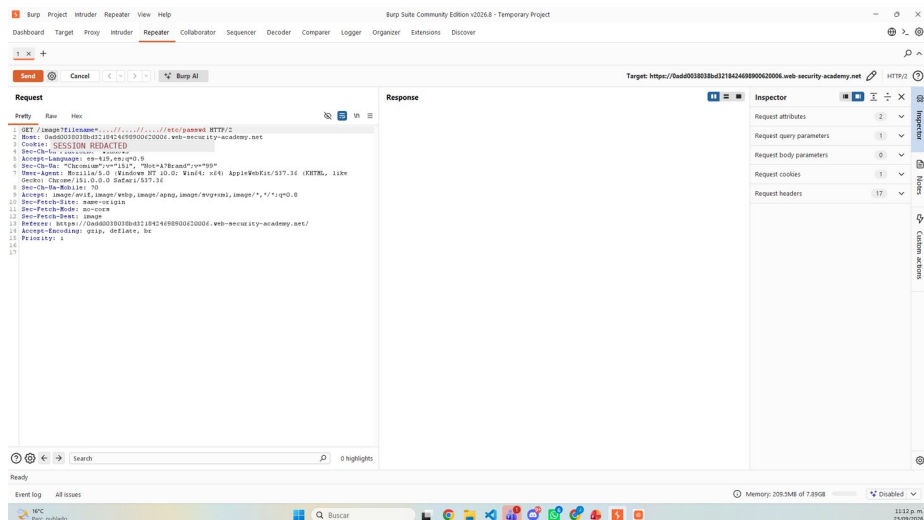
4.5 Envío de la petición a Repeater

Se hizo clic derecho sobre la petición seleccionada y se eligió la opción "Send to Repeater" del menú contextual, para poder modificar y reenviar la petición manualmente.



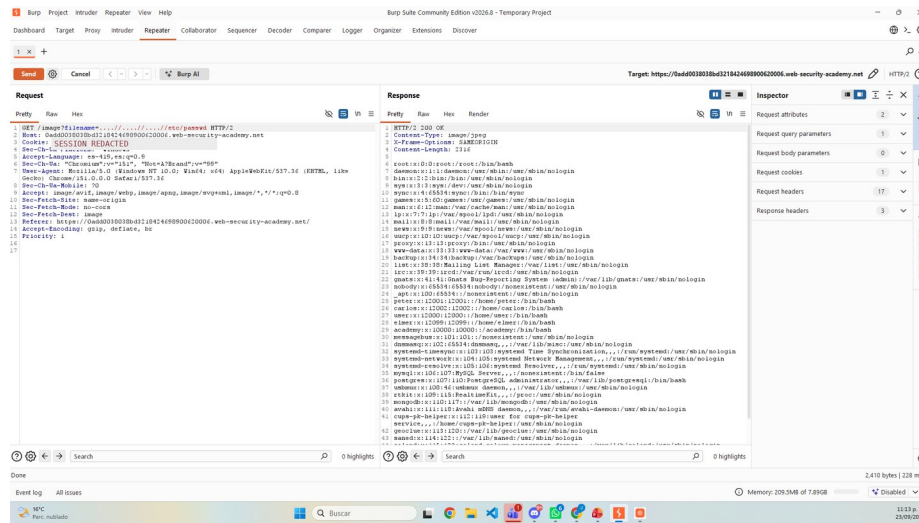
4.6 Payload de bypass no recursivo

Se reemplazó el valor del parámetro filename por el payload//....//....//etc/passwd, diseñado para explotar la eliminación no recursiva del patrón ".." por parte del filtro.



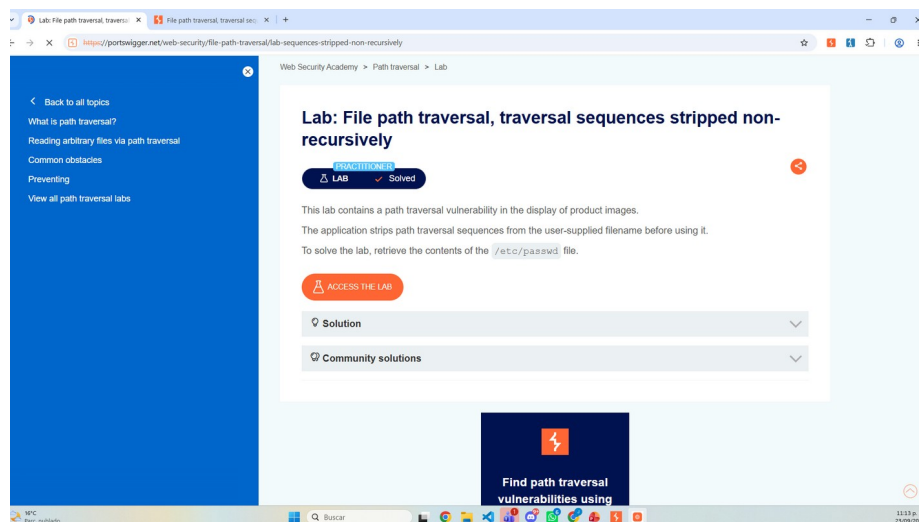
4.7 Respuesta vulnerable

Al enviar la petición, el servidor respondió "HTTP/2 200 OK", devolviendo el contenido completo del archivo `/etc/passwd` y confirmando que el filtro de eliminación no recursiva fue evadido con éxito.



4.8 Confirmación "Lab Solved"

Al regresar a la página oficial del laboratorio en PortSwigger y refrescarla, el indicador de estado cambió de "Not solved" a "Solved", confirmando que el objetivo de recuperar el contenido de `/etc/passwd` se cumplió exitosamente.



5. Explicación del payload

Payload utilizado://....//....//etc/passwd

- El filtro de la aplicación busca la subcadena "../" dentro del valor recibido y la elimina, pero realiza esta búsqueda una sola vez sobre el string original, sin volver a analizar el resultado después de la eliminación.
- Cada bloque "...//" (cuatro puntos seguidos de dos barras) contiene, entre sus caracteres centrales, una ocurrencia del patrón "../". Al eliminarla, los caracteres que quedan a ambos lados se recombinan, formando nuevamente la secuencia "../", que el filtro ya no vuelve a detectar.
- Al repetir este bloque tres veces (....//....//....//), se generan tres secuencias "../" funcionales tras el filtrado, suficientes para subir desde el directorio de imágenes hasta la raíz del sistema de archivos.
- Una vez en la raíz, "etc/passwd" completa la ruta hacia el archivo objetivo, que el servidor termina leyendo y devolviendo sin darse cuenta de que su filtro fue evadido.

6. Incidencias durante la práctica

- Filtro de contenido en Burp: al iniciar un nuevo proyecto, el filtro de HTTP history ocultaba nuevamente el contenido de imágenes por defecto ("Hiding CSS and image content; hiding specific extensions"). Fue necesario repetir el ajuste de "Filter by MIME type" (marcar "Images") y vaciar el campo "Hide" en "Filter by file extension", tal como en las actividades anteriores.
- Ninguna otra incidencia relevante: el payload//....//....//etc/passwd funcionó correctamente desde el primer intento, obteniendo una respuesta "200 OK" con el contenido de /etc/passwd.

7. Mitigación recomendada

- Aplicar el filtro de eliminación de secuencias de forma recursiva o iterativa, repitiendo la búsqueda y eliminación del patrón "../" hasta que no queden más coincidencias en el string resultante.
- Preferir la canonicalización de la ruta (resolver la ruta real, por ejemplo con funciones como `realpath()`) sobre el filtrado de patrones, y verificar que el resultado final se encuentre dentro del directorio permitido.
- Utilizar listas blancas (whitelisting) de nombres de archivo permitidos, en lugar de depender de la eliminación de patrones maliciosos conocidos (blacklisting).
- Usar identificadores indirectos (por ejemplo, un ID numérico mapeado internamente a la ruta real del archivo) en lugar de aceptar directamente nombres o rutas de archivo proporcionados por el usuario.
- Aplicar el principio de mínimo privilegio, ejecutando la aplicación con permisos de sistema de archivos restringidos para limitar el impacto de una posible lectura no autorizada.

8. Conclusión

Este laboratorio permitió comprender que una sanitización de entrada aplicada de forma no recursiva puede ser evadida construyendo cuidadosamente el payload para que, tras la primera pasada del filtro, se regenere la secuencia maliciosa original. Se reforzó la idea de que las defensas basadas en la eliminación de patrones específicos deben aplicarse de forma iterativa o, preferiblemente, sustituirse por una validación basada en la ruta final canonicalizada.

Referencias

PortSwigger. (2026). File path traversal, traversal sequences stripped non-recursively

[Laboratorio interactivo]. Web Security Academy.

<https://portswigger.net/web-security/file-path-traversal/lab-sequences-stripped-non-recursively>

OWASP Foundation. (2021). OWASP Top 10:2021 – A01 Broken Access Control.

https://owasp.org/Top10/A01_2021-Broken_Access_Control/